Teknova Veri Sistemleri A.Ş. Web Uygulaması Sızma Testi Raporu

Hazırlayan: Volkan ÖZDEMİR

Tarih: 3 Mart, 2026
Doküman No: 1042-032026
Versiyon: 1.0

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

İçindekiler

Tablo Listesi 3
Şekil Listesi 4
1. Genel Bilgiler 5
1.1. Doküman Bilgileri 5
1.1.1. Raporun Detayların 5
1.3.2. Müşteri Kurum Yetkilisi 5
1.3.3. Rapor Denetimi 5
1.3.4. Dağıtım Listesi 5
1.2. Yasal Sorumluluklar 5
1.3. Giriş 6
1.4. Kapsam 6
1.4.1. Testlerin Gerçekleştirildiği Kullanıcı Profilleri 6
2. Yönetici Özeti 7
2.1 Metadoloji Açıklaması 8
2.2. Bulgulara Yönelik Önem Dereceleri 9
2.3. Bulgulara Yönelik Özet Dağılım Tablosu 10
2.4. Etki Biçimlerine Göre Bulguların Dağılımı 10
2.5. Bulgu ve İş Etki Dağılımı 10
2.6. Bulgu Sebebine Göre Dağılımı 11
2.7. Erişim Noktalarına Göre Bulguların Dağılımı 11
3. Teknik Bilgiler ve Detaylar 12
3.1. Brute Force (Kaba Kuvvet) Saldırısına Karşı Savunmasızlık 12
3.2. Hız Sınırlaması (Rate Limiting) Eksikliği 13
3.3. HTTP DoS (Slowloris) Savunmasızlığı 14
3.4. Hassas Bilgilerin GET Methodu ile URL Üzerinden İletilmesi 15
3.4. Güvensiz İletişim Protokolü Kullanımı (Missing SSL/TLS) 16
4. Sonuç (Genel Değerlendirme) 17
5. Kullanılan Kısaltmalar ve Terimler Sözlüğü 18
6. Kullanılan Araçlar 19
6.1. Burp Suite (Intruder) 19
6.2. Hydra 19
6.3. Slowhttptest 19
6.4. Waterfox / Tarayıcı Geliştirici Araçları 19

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

Tablo Listesi

Table 1. Raporun detay bilgileri 5
Table 2. Müşteri kurum yetkilisi bilgileri 5
Table 3. Rapor denetimi ve sürüm geçmişi 5
Table 4. Dağıtım listesi ve erişim yetkileri 5
Table 5. Sızma testi kapsam içeriği 6
Table 6. Test gerçekleştirilen kullanıcı profilleri 6
Table 7. Bulgu dağılımlarının özeti 10
Table 8. Bulguların etki biçimlerine göre dağılımı 10

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

Şekil Listesi

Figure 1. Kullanılan test metodolojisi 8
Figure 2. Bulgu önem dereceleri 9
Figure 3. Bulgu ve iş etki dağılımı 10
Figure 4.. Bulguların erişim noktalarına göre dağılımı 11
Figure 5. Bulgu sebebine göre bulguların dağılımı 11
Figure 6. Kaba kuvvet saldırısı ile yönetici hesabının ele geçirilmesi 12
Figure 7. Hız sınırlamasının denetlenmesi 13
Figure 8. HTTP DoS test simülasyonu 14
Figure 9. Hassas bilgilerin GET methodu ile iletilmesi 15
Figure 10. Güvensiz iletişim protokolü kullanımı 16

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

1. Genel Bilgiler

1.1. Doküman Bilgileri

1.1.1. Raporun Detayların

Alan	Bilgi
Rapor Başlığı	Teknova Veri Sistemleri A.Ş. Web Uygulaması Sızma Testi Raporu
Versiyon	V1.0
Yazan	Volkan Özdemir
Test Ekibi	Volkan Özdemir, Kaan Demir, Selin Yılmaz
Kontrol Eden	Mert Sayer
Onaylayan	Erdem Canöz
Rapor Sınıfı	Gizli

Table 1. Raporun detay bilgileri

1.3.2. Müşteri Kurum Yetkilisi

Yetkili Adı ve Soyadı	Ünvan	Kurum Adı
Ufuk Kaya	Bilgi Güvenliği Direktörü	Teknova Veri Sistemleri A.Ş.

Table 2. Müşteri kurum yetkilisi bilgileri

1.3.3. Rapor Denetimi

Versiyon	Tarih	Yazar	Tanım
V1.0	03.03.2026	Volkan ÖZDEMİR	Final

Table 3. Rapor denetimi ve sürüm geçmişi

1.3.4. Dağıtım Listesi

İsim/Kurum	Bölüm/Ünvan	Erişim Seviyesi
Teknova Veri Sistemleri A.Ş.	Bilgi Güvenliği ve Risk Yönetimi Ekibi	Tam Erişim
Teknova Veri Sistemleri A.Ş.	Uygulama Güvenliği (AppSec) Ekibi	Sınırlı Erişim
Özdemir Siber Güvenlik	Proje Arşivi	Salt Okunur

Table 4. Dağıtım listesi ve erişim yetkileri

1.2. Yasal Sorumluluklar

Bu rapor, Teknova Veri Sistemleri A.Ş. için hazırlanmış olup gizli derecede teknik veriler içermektedir. Belge içeriğinin tamamı veya bir kısmı, denetim ekibinin yazılı izni olmaksızın üçüncü şahıslarla paylaşılamaz ve kopyalanamaz.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

Raporda sunulan güvenlik iyileştirmelerinin sistemlere entegrasyonu tamamen kurumun sorumluluğundadır. Bu önerilerin uygulanması esnasında oluşabilecek sistem kesintileri, veri kayıplarından ekibimiz hiçbir şekilde mesuliyet kabul etmez. Teknik tavsiyelerin, kurumun operasyonel sürekliliği gözetilerek kontrollü bir ortamda test edilmesi şiddetle önerilir.

1.3. Giriş

Bu rapor, Özdemir Siber Güvenlik Limited Şirketi tarafından "Teknova Veri Sistemleri A.Ş." web uygulamaları üzerindeki güvenlik açıklarını tespit etmek amacıyla 15.02.2026 – 02.03.2026 tarihleri arasında gerçekleştirilen sızma testinin detaylı sonuçlarını ve çözüm önerilerini içermektedir.

Gerçekleştirilen pentest çalışması kapsamında; Teknova Veri Sistemleri bilişim altyapısının ve sunucularının sürekliliğini olumsuz yönde etkileyecek kontrolsüz araçlar ve yöntemler kullanılmamış, kurumun onayı ve bilgisi dışında hizmetin aksamasına neden olabilecek herhangi bir işlem gerçekleştirilmemiştir. Testler, önceden belirlenen kapsam dahilinde ve iş akışını sekteye uğratmayacak şekilde kontrollü bir saldırgan bakış açısıyla icra edilmiştir.

1.4. Kapsam

Sızma testinde ana amaçlardan biri, hedef sistemlerdeki tüm zafiyetlerin bütüncül bir bakış açısıyla değerlendirilerek sisteme sızılmaya çalışılmasıdır. Bu amaç doğrultusunda gerçekleştirilecek sızma testlerinde "Kapsam" (Scope), pentest çalışmasının en kritik ve belirleyici adımını oluşturmaktadır.

Gerçekleştirilen denetimlerde Teknova Veri Sistemleri A.Ş. yetkilileri tarafından bildirilen ve Tablo 5'de teknik detayları verilen sistemlere yönelik kapsamlı sızma testleri gerçekleştirilmiştir.

Çalışma/Test Alanı	Açıklama
192.168.0.0/24	Yerel Ağ
http://192.168.0.40	Web

Table 5. Sızma testi kapsam içeriği

1.4.1. Testlerin Gerçekleştirildiği Kullanıcı Profilleri

Kullanıcı Profilleri	Açıklama
Yetkili Kullanıcı	Kimlik doğrulaması gerçekleştirilmiş ve sistem üzerindeki kaynaklara erişiminde yetki kısıdı minimum düzeyde olan kullanıcıları göstermek için tanımlanmış profildir.
Yetkisiz Kullanıcı	Kimlik doğrulama mekanizmasından geçen fakat sistem kaynaklarına erişimi yetkilendirme mekanizmaları tarafından kısıtlanan kullanıcıları göstermek için tanımlanmış profildir
Anonim Kullanıcı	Kimlik doğrulama ve yetkilendirme mekanizmaları tarafından korunan kaynaklara erişemeyen kullanıcıları göstermek için tanımlanmış profildir.

Table 6. Test gerçekleştirilen kullanıcı profilleri

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

2. Yönetici Özeti

Testi kapsamında, internet üzerinden erişim sağlayan anonim bir saldırgan bakış açısıyla, kapsam dahilinde belirtilen Teknova Veri Sistemleri dijital varlıklarına yönelik denetimler gerçekleştirilmiştir. Denetim süreci, otomatize zafiyet tarama araçlarının sunduğu verilerin ardından, bu araçların tespit edemeyeceği karmaşık mantıksal hataları ve zafiyetleri ortaya çıkarmak amacıyla ileri seviye manuel tekniklerle desteklenmiştir.

Yapılan testler sonucunda, dış dünyaya açık giriş paneli üzerinde gerçekleştirilen Kaba Kuvvet (Brute Force) senaryolarında, giriş mekanizmasının ardışık hatalı denemeleri engelleyecek bir hız sınırlama (Rate Limiting) mekanizmasına sahip olmadığı saptanmıştır. Bu denetim eksikliği, saniyede yüzlerce şifre kombinasyonunun denenmesine olanak tanıyarak admin yetkili kullanıcısının parolasının ele geçirilmesine yol açmıştır. Bunun yanı sıra, uygulama katmanında gerçekleştirilen hizmet dışı bırakma (Slowloris DoS) testlerinde, sunucuya iletilen HTTP başlıklarının zaman aşımına uğradığı tespit edilmiştir. Yapılan sömürü faaliyeti neticesinde sunucu kaynakları (bağlantı havuzu) sadece 240 saniye içerisinde tükenmiş ve servis kullanıcılara tamamen kapanmıştır.

Denetimler sırasında web uygulamalarının herhangi bir SSL/TLS şifreleme protokolü kullanmadığı (Plaintext HTTP) tespit edilmiştir. Bu durum, kullanıcı ile sunucu arasındaki veri trafiğinin şifrelenmediğini ve ağ üzerindeki bir saldırganın tüm trafiği açık metin olarak izleyebileceğini göstermektedir. Ayrıca, uygulama içerisinde kullanıcı adı ve parola gibi son derece hassas verilerin HTTP GET metodu ile URL üzerinden iletildiği saptanmıştır. Bu yöntem, gizli bilgilerin tarayıcı geçmişinde, sunucu loglarında ve referer başlıklarında kalıcı olarak sızmasına neden olan ciddi bir yapılandırma hatasıdır.

Sonuç olarak; tek başına yıkıcı etkisi olmayan ancak bir saldırganın daha karmaşık saldırılar kurgulaması için "basamak" görevi görebilecek orta seviyeli bulguların yanı sıra, doğrudan sistem yetkilerinin kaybedilmesine veya iş sürekliliğinin bozulmasına yol açan kritik ve yüksek seviyeli bulguların ivedilikle giderilmesi önerilmektedir. Tespit edilen bu açıkların kapatılması, kurumun genel siber güvenlik olgunluk seviyesini arttıracaktır.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

2.1 Metadoloji Açıklaması

Sızma testlerinde, PTES (Penetration Testing Execution Standart) metodolojisi temel alınmıştır. Metodoloji toplam yedi bölümden oluşmaktadır.

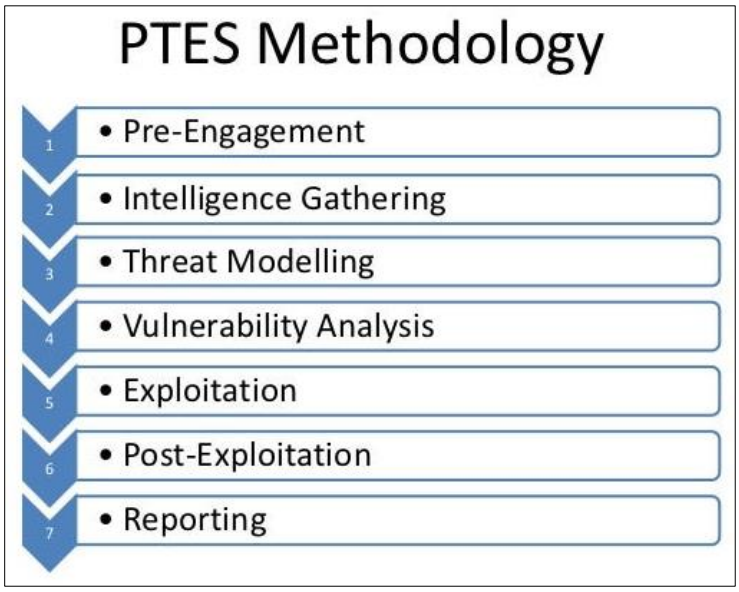


Figure 1. Kullanılan test metodolojisi

1. **Ön Hazırlık (Pre-Engagement):** Test başlamadan önce kapsam, hedef sistemler, izinler ve test süresi belirlenir. Bu aşamada müşteri ile testin sınırları ve kuralları netleştirilir.

2. **Bilgi Toplama (Intelligence Gathering):** Hedef sistem hakkında mümkün olduğunca fazla bilgi toplanır. IP adresleri, domainler, açık portlar ve kullanılan teknolojiler analiz edilir.

3. **Tehdit Modellemesi (Threat Modelling):** Toplanan bilgiler doğrultusunda hedefe yönelik olası saldırı senaryoları oluşturulur ve hangi varlıkların daha kritik olduğu belirlenir.

4. **Zafiyet Analizi (Vulnerability Analysis):** Sistemlerde bulunan güvenlik açıkları tespit edilir. Yanlış yapılandırmalar, güncel olmayan yazılımlar veya uygulama açıkları bu aşamada belirlenir.

5. **Sömürü (Exploitation):** Tespit edilen güvenlik açıkları kullanılarak sisteme yetkisiz erişim sağlanmaya çalışılır. Amaç, açığın gerçekten istismar edilip edilemeyeceğini göstermektir.

6. **Sömürü Sonrası (Post-Exploitation):** Sisteme erişim sağlandıktan sonra saldırganın ne kadar ilerleyebileceği analiz edilir. Yetki yükseltme, ağ içinde hareket etme ve hassas verilere erişim değerlendirilir.

7. **Raporlama (Reporting):** Test sonucunda elde edilen tüm bulgular rapor haline getirilir. Raporda güvenlik açıkları, risk seviyeleri ve çözüm önerileri yer alır.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

2.2. Bulgulara Yönelik Önem Dereceleri

Herhangi bir niteliği, özelliği bulunmayan bir saldırgan tarafından kurum veya kuruluşun dış ağından gerçekleştirilen ve sistemin tamamen ele geçirilmesi ile sonuçlanabilen saldırılara neden olan açıklardır.

Belirli özellik ve niteliklere sahip bir saldırgan tarafından kurum veya kuruluşun dış ağından gerçekleştirilen ve sistemin tamamen ele geçirilmesi ile sonuçlanabilen saldırılara neden olan açıklardır.

Kurum veya kuruluş dış ağından gerçekleştirilen ve kısıtlı yetki yükseltilmesi veya hizmet dışı olma gibi bir durumla sonuçlanabilen, bununla birlikte yerel ağ ya da sunucu üzerinden gerçekleştirilen ve yetki yükseltmeyi sağlayan saldırılara neden olan açıklardır.

Kurum veya kuruluşun yerel ağı veya sunucu üzerinden gerçekleştirilen ve hizmet dışı olma ile sonuçlanan saldırılara neden olan açıklardır.

Sonuçlarının net olarak belirlenemediği sıkılaştırma yöntemlerinin izlenmemesinden kaynaklanan düşük seviyeli eksikliklerdir.

Figure 2. Bulgu önem dereceleri

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

2.3. Bulgulara Yönelik Özet Dağılım Tablosu

	Acil	Kritik	Yüksek	Orta	Düşük	Toplam
Web Uygulamaları		1	2	1		4
Sunucu/İstemci Sistemler						
DDOS Testleri				1		1
Network Sistemleri						
Veritabanı Sistemleri						
Kablosuz Ağ Sistemleri						
Toplam						5

Table 7. Bulgu dağılımlarının özeti

2.4. Etki Biçimlerine Göre Bulguların Dağılımı

Bulgu Adı	İş Etkisi (Business Impact)	Çözüm Önerisi
Brute Force	Personel hesaplarının çalınması ve itibar kaybı.	Güvenlik Mekanizması
DoS Saldırısı	Servislerin tamamen erişilmez hale gelmesi.	Timeout Limitleri
Hız Sınırlama Eksikliği	Otomatik saldırı araçlarıyla hesaplarının ele geçirilme riskini artırır.	Rate Limiting / CAPTCHA
Güvensiz İletişim	Ağ trafiğinin izlenmesiyle hassas verileri riske atar.	SSL/TLS Sertifikası
Givensiz Method Kullanımı	Şifrelerin açık metin olarak kalmasına yol açar.	POST Methodu Kullanımı

Table 8. Bulguların etki biçimlerine göre dağılımı

2.5. Bulgu ve İş Etki Dağılımı

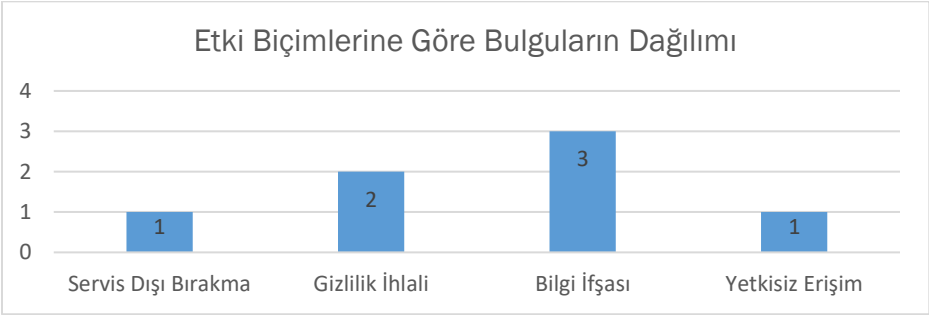


Figure 3. Bulgu ve iş etki dağılımı

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

2.6. Bulgu Sebebine Göre Dağılımı

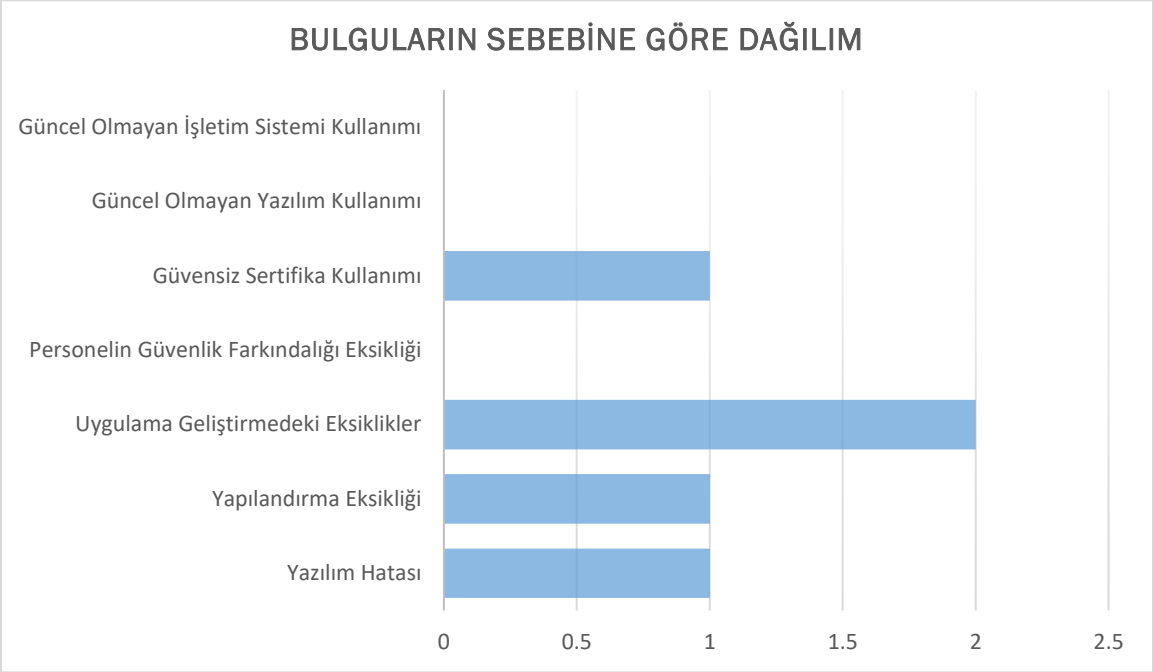


Figure 4.. Bulguların erişim noktalarına göre dağılımı

2.7. Erişim Noktalarına Göre Bulguların Dağılımı

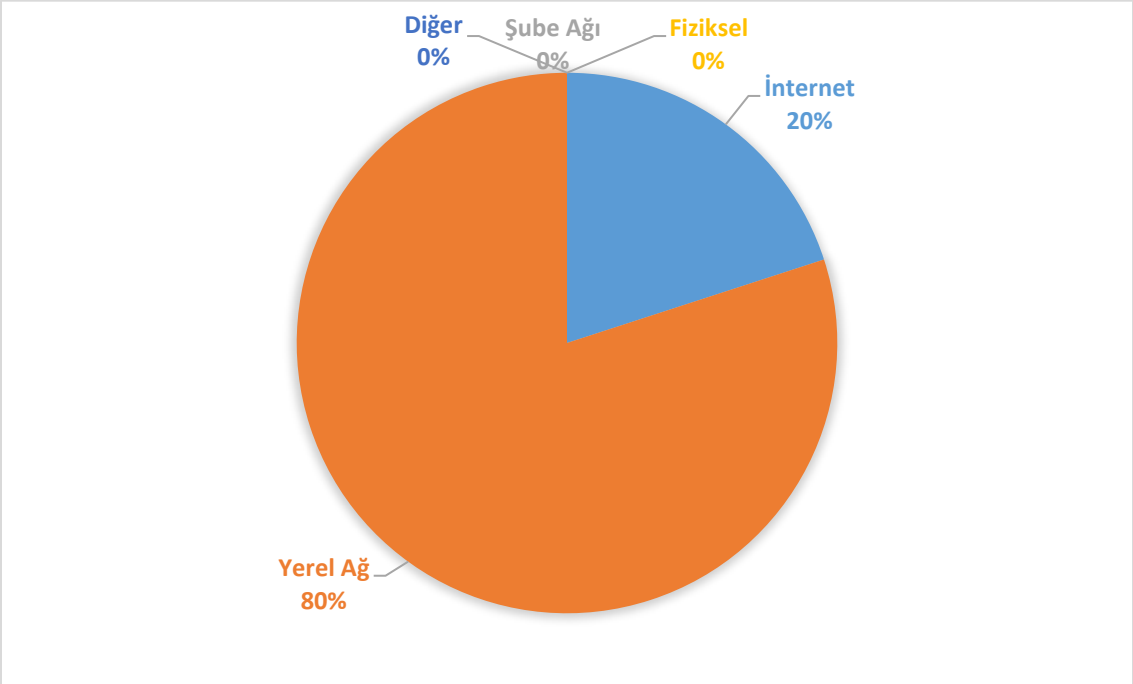


Figure 5. Bulgu sebebine göre bulguların dağılımı

3. Teknik Bilgiler ve Detaylar

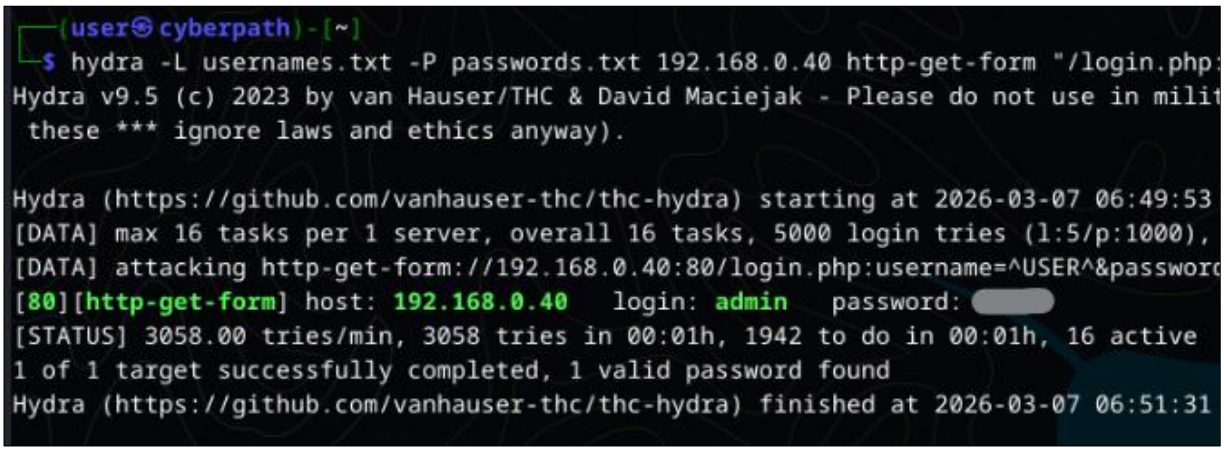
3.1. Brute Force (Kaba Kuvvet) Saldırısına Karşı Savunmasızlık

KRİTİK	**Bulgu Adı**	Brute Force (Kaba Kuvvet) Saldırısına Karşı Savunmasızlık
	Erişim Noktası	http://192.168.0.40/login.php
	Özet	Hedef sistemde herhangi bir hesap kilitleme veya hız sınırlama mekanizması bulunmadığı için admin hesabı, kullanılan zayıf parola nedeniyle kaba kuvvet (brute force) saldırısıyla tam yetkili olarak ele geçirilmiştir.

Bulgu Açıklaması

Gerçekleştirilen testte hydra aracı kullanılarak "usernames.txt" ve "passwords.txt" listeleri üzerinden bir saldırı simüle edilmiştir. Yapılan analiz sonucunda şu eksiklikler saptanmıştır:

1. Hesap Kilitleme Mekanizması Yok: Saldırgan kısa sürede (yaklaşık 2 dakikada) 3000'den fazla deneme yapabilmiştir. Sunucu, bu yoğun hatalı giriş denemelerini engellememiştir.
2. Zayıf Parola Kullanımı: admin hesabı için kullanılan parola, yaygın kelime listelerinde (wordlist) bulunan ve saniyeler içinde kırılabilecek düşük karmaşıklıkta bir paroladır.
3. Bulgu Kritikliği: Yönetici hesabının ele geçirilmesi, saldırgana sistem üzerinde tam yetki sağlayarak veri sızıntısına veya sistemin tamamen kontrol altına alınmasına yol açar.



```
┌──(user㉿cyberpath)-[~]
└─$ hydra -L usernames.txt -P passwords.txt 192.168.0.40 http-get-form "/login.php:
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milit
 these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-07 06:49:53
[DATA] max 16 tasks per 1 server, overall 16 tasks, 5000 login tries (l:5/p:1000),
[DATA] attacking http-get-form://192.168.0.40:80/login.php:username=^USER^&passwor
[80][http-get-form] host: 192.168.0.40   login: admin   password: [redacted]
[STATUS] 3058.00 tries/min, 3058 tries in 00:01h, 1942 to do in 00:01h, 16 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-07 06:51:31
```

Figure 6. Kaba kuvvet saldırısı ile yönetici hesabının ele geçirilmesi

Çözüm Önerileri

Bu açığı kapatmak için aşağıdaki adımlar atılabilir:

- Güçlü Parola Politikası
- Hesap Kilitleme (Account Lockout)
- 2FA/MFA Kullanımı
- CAPTCHA Uygulaması
- Güvenlik Yazılımları

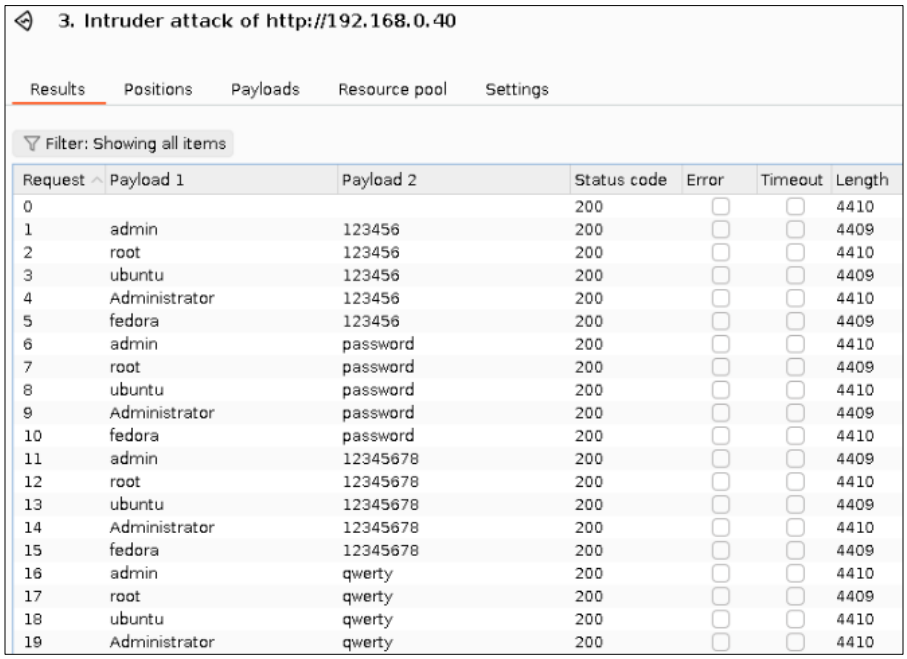
Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

3.2. Hız Sınırlaması (Rate Limiting) Eksikliği

YÜKSEK	**Bulgu Adı**	Hız Sınırlaması (Rate Limiting) Eksikliği
	Erişim Noktası	http://192.168.0.40/login.php
	Özet	Uygulama giriş panelinde, ardışık hatalı denemeleri engelleyecek bir hız sınırlaması (rate limiting) bulunmamaktadır. Bu durum, saldırganların çok sayıda kullanıcı adı ve parola kombinasyonunu kısa sürede deneyerek hesapları ele geçirmesine imkan tanımaktadır.

Bulgu Açıklaması

Gerçekleştirilen testte, Burp Suite aracıyla saniyeler içinde yüzlerce farklı kimlik bilgisi (admin, root, administrator vb.) gönderilmiştir. Sunucunun tüm bu isteklere kesintisiz olarak "200 OK" yanıtı vermesi, herhangi bir güvenlik engellemesi (IP ban, hesap kilitleme veya CAPTCHA) olmadığını kanıtlamıştır. Bu kontrolsüz erişim, hem hesapların ele geçirilmesine hem de sunucu kaynaklarının gereksiz tüketilmesine neden olmaktadır.



Request	Payload 1	Payload 2	Status code	Error	Timeout	Length
0			200			4410
1	admin	123456	200			4409
2	root	123456	200			4410
3	ubuntu	123456	200			4409
4	Administrator	123456	200			4410
5	fedora	123456	200			4409
6	admin	password	200			4410
7	root	password	200			4409
8	ubuntu	password	200			4410
9	Administrator	password	200			4409
10	fedora	password	200			4410
11	admin	12345678	200			4409
12	root	12345678	200			4410
13	ubuntu	12345678	200			4409
14	Administrator	12345678	200			4410
15	fedora	12345678	200			4409
16	admin	qwerty	200			4410
17	root	qwerty	200			4409
18	ubuntu	qwerty	200			4410
19	Administrator	qwerty	200			4410

Figure 7. Hız sınırlamasının denetlenmesi

Çözüm Önerileri

Bu açığı kapatmak için aşağıdaki adımlar atılabilir:

- Hız Sınırlama Mekanizması (Rate Limiting)
- CAPTCHA Entegrasyonu
- Hesap Kitleme Politikası
- WAF Kullanımı

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

3.3. HTTP DoS (Slowloris) Savunmasızlığı

YÜKSEK	**Bulgu Adı**	Hız Sınırlaması (Rate Limiting) Eksikliği
	Erişim Noktası	http://192.168.0.40
	Özet	Web sunucusuna, gönderilen bağlantıların zaman aşımına uğratıldığı tespit edilmiştir. Bu durum, kısıtlı bir bant genişliğiyle bile sunucunun bağlantı havuzunun işgal edilmesine ve servisin kapanmasına neden olmaktadır.

Bulgu Açıklaması

Yapılan testte 1000 eşzamanlı bağlantı denenmiş ve her 10 saniyede bir veri gönderilerek bağlantılar açık tutulmuştur. Analiz sonucunda:

- Servis Kesintisi: Sunucu kapasitesi dolmuş ve taleplere yanıt vermeyi tamamen kesmiştir.
- Kaynak Tüketimi: Sunucu, sadece 324 adet bağlantıyı yönetmeye çalışırken tüm bağlantı havuzunu tüketmiş ve kilitlenmiştir.

Figure 8. HTTP DoS test simülasyonu

Çözüm Önerileri

Bu açığı kapatmak için aşağıdaki adımlar atılabilir:

- Timeout Ayarları
- Bağlantı Limitleri
- WAF ve IPS Kullanımı

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

3.4. Hassas Bilgilerin GET Methodu ile URL Üzerinden İletilmesi

ORTA	**Bulgu Adı**	Hassas Bilgilerin GET Metodu ile URL Üzerinden İletilmesi
	Erişim Noktası	http://192.168.0.40/login.php
	Özet	Uygulama, kullanıcı giriş bilgilerini HTTP POST metodu yerine GET metodu ile göndermektedir. Bu durum, parolalar dahil tüm hassas verilerin URL çubuğunda açıkça görünmesine neden olur.

Bulgu Açıklaması

Görselde görüldüğü üzere, giriş denemesi yapıldığında kullanıcı adı ve şifre URL'ye eklenmektedir (login.php?username=test&password=test...). Bu yöntem şu ciddi güvenlik risklerini doğurur:

- Tarayıcı Geçmişi: Parolalar tarayıcı geçmişine kaydedilir.
- Sunucu Kayıtları: Web sunucusu loglarında (access.log) şifreler açık metin (clear-text) olarak saklanır.
- Omuz Üstü Sörf: Şifre, ekranı gören herkes tarafından fiziksel olarak okunabilir.
- Referer Başlıkları: Kullanıcı başka bir siteye yönlenirse, parola bilgisi "Referer" başlığı ile üçüncü taraf sitelere sızabilir.

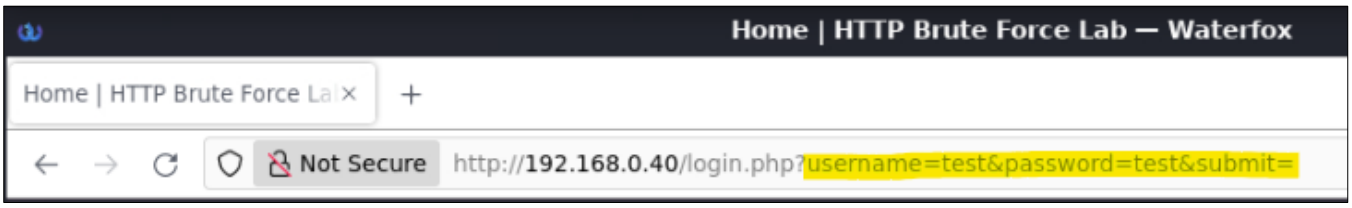


Figure 9. Hassas bilgilerin GET methodu ile iletilmesi

Çözüm Önerileri

Bu açığı kapatmak için aşağıdaki adımlar atılabilir:

- POST Metodu Kullanımı: Giriş formlarında hassas veriler (şifre, kredi kartı vb.) kesinlikle HTTP POST metodu ile gönderilmelidir.
- HTTPS/TLS Geçişi: Verilerin ağ üzerinde izlenmesini engellemek için iletişim uçtan uca şifrelenmelidir.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

3.4. Güvensiz İletişim Protokolü Kullanımı (Missing SSL/TLS)

ORTA	**Bulgu Adı**	Güvensiz İletişim Protokolü Kullanımı
	Erişim Noktası	http://192.168.0.40
	Özet	Web sunucusunun HTTPS şifreleme protokolünü desteklemediği ve tüm veri trafiğinin açık metin (clear-text) üzerinden iletildiği tespit edilmiştir. Bu durum, ağ trafiğini izleyen bir saldırganın tüm verileri hiçbir engelle karşılaşmadan okumasına neden olur.

Bulgu Açıklaması

Görselde görüldüğü üzere, tarayıcı bağlantının güvenli olmadığını (You are not securely connected to this site) açıkça belirtmektedir. SSL/TLS sertifikasının eksikliği şu riskleri doğurur:

- Ortadaki Adam (MitM) Saldırıları: Aynı ağdaki bir saldırgan, kullanıcıların gönderdiği kullanıcı adı ve şifre gibi hassas bilgileri sniffing yöntemi ile ele geçirebilir.
- Veri Bütünlüğü Riski: Şifrelenmemiş trafik üzerinden iletilen veriler, saldırganlar tarafından iletim sırasında değiştirilebilir (örneğin indirilen bir dosyanın içine zararlı yazılım enjekte edilmesi).
- Güven Eksikliği: Kullanıcılar, tarayıcıda gördükleri "Güvenli Değil" uyarısı nedeniyle sisteme güven duymayacaktır.

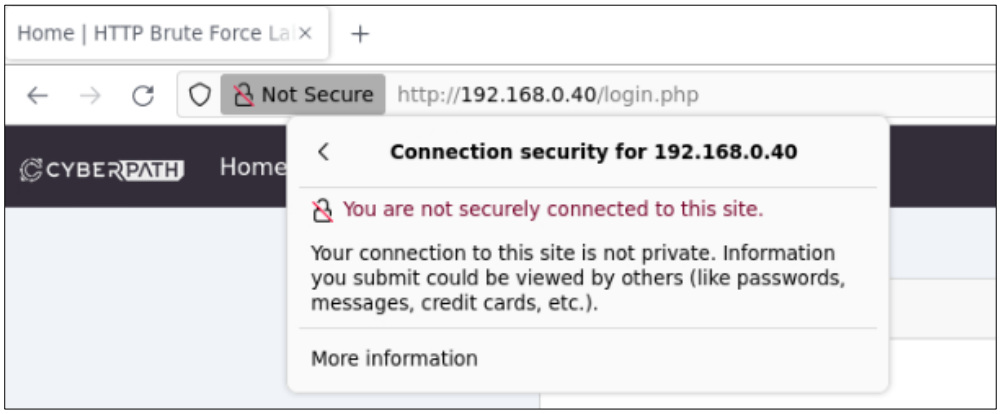


Figure 10. Güvensiz iletişim protokolü kullanımı

Çözüm Önerileri

Bu açığı kapatmak için aşağıdaki adımlar atılabilir:

- SSL/TLS Sertifikası Kurulumu: Sunucuya geçerli bir SSL/TLS sertifikası kurulmalıdır.
- HTTPS Yönlendirmesi: HTTP üzerinden gelen tüm istekler otomatik olarak HTTPS protokolüne yönlendirilmelidir.
- HSTS Yapılandırması: Tarayıcıların siteye her zaman güvenli bağlantı üzerinden erişmesini zorunlu kılan HSTS (HTTP Strict Transport Security) başlığı sunucuya eklenmelidir.
- Güvenli Çerezler: Oturum çerezlerine “Secure” bayrağı eklenerek, bu çerezlerin sadece şifreli bağlantılar üzerinden gönderilmesi sağlanmalıdır.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

4. Sonuç (Genel Değerlendirme)

Test kapsamında, kurumun ağ yapısı üzerinde belirlenen hedef IP bloklarına yönelik hem otomatize tarama araçları hem de manuel sızma testi teknikleri kullanılarak kapsamlı bir analiz gerçekleştirilmiştir. Test süreci, ağ üzerindeki servislerin keşfi ve zafiyet taramaları ile başlamış, ardından otomatize araçların tespit edemediği mantıksal hatalar ve protokol zayıflıkları manuel senaryolarla derinleştirilmiştir. Bu kapsamda, özellikle uygulama katmanı ve ağ güvenliği özelinde kritik ve yüksek seviyeli zafiyetler tespit edilmiştir.

Kritik seviyede bir bulgu olarak, hedef sistem üzerinde gerçekleştirilen kaba kuvvet (Brute Force) saldırısı sonucunda, zayıf parola politikası ve hız sınırlaması (Rate Limiting) mekanizmasının eksikliği nedeniyle admin yetkili kullanıcısına ait kimlik bilgileri başarıyla ele geçirilmiştir. Bu durum, saldırganın sistem üzerinde tam kontrol sağlamasına ve yetkisiz erişim elde etmesine olanak tanımaktadır. Yüksek seviyeli bir zafiyet olarak ise sunucunun Slow HTTP DoS (Slowloris) saldırılarına karşı tamamen savunmasız olduğu, yapılan sömürü faaliyeti sonucunda servisin sadece 240 saniye içerisinde kullanıcılara hizmet veremez hale geldiği (service available: NO) gözlemlenmiştir.

Ayrıca orta seviyeli bulgular kapsamında, web sunucusunun SSL/TLS şifreleme protokollerini desteklemediği, tüm trafiğin şifresiz HTTP üzerinden aktığı tespit edilmiştir. Bu durum, giriş bilgileri gibi hassas verilerin ağ üzerinde sniffing ile ele geçirilmesine zemin hazırlamaktadır. Veri gizliliğini tehdit eden bir diğer unsur olarak, kullanıcı adı ve parola gibi hassas parametrelerin URL üzerinde GET metodu ile taşındığı görülmüştür. CVSS skoru baz alınarak yapılan değerlendirmeler neticesinde; 1 adet kritik (Yönetici hesabı ele geçirme), 2 adet yüksek (DoS ve No Rate Limiting) ve 2 adet orta seviyeli (Eksik SSL ve Insecure GET) olmak üzere toplamda 5 ana başlıkta zafiyet tespit edilmiştir.

Sonuç olarak, özellikle tam yetkili hesap erişimine ve servis kesintisine imkan veren kritik ve yüksek seviyeli açıkların vakit kaybedilmeden giderilmesi, kurumun iş sürekliliği ve veri güvenliği açısından büyük önem arz etmektedir. Tespit edilen tüm bu zafiyetlerin teknik detayları, sömürü aşamaları ve çözüm önerileri, ekran görüntüleri ile desteklenmiş şekilde raporun “Teknik Bilgiler ve Detaylar” bölümünde sunulmuştur.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

5. Kullanılan Kısaltmalar ve Terimler Sözlüğü

2FA/MFA

- Two-Factor / Multi-Factor Authentication: İki veya Çok Faktörlü Kimlik Doğrulama; parola dışında ek bir doğrulama katmanı (SMS kodu, mobil onay vb.) ekleyen güvenlik sistemidir.

B

- Brute Force (Kaba Kuvvet): Bir saldırganın, doğru kimlik bilgilerini bulana kadar binlerce farklı şifre kombinasyonunu otomatik araçlarla denediği saldırı türüdür.

C

- CAPTCHA: İnsan ve bilgisayar ayrımı yapmak için kullanılan, kullanıcıların bot olmadığını kanıtlamasını sağlayan güvenlik testidir.
- CVSS: Common Vulnerability Scoring System (Ortak Zafiyet Puanlama Sistemi); güvenlik açıklarının şiddetini (Kritik, Yüksek, Orta, Düşük) belirlemek için kullanılan standarttır.
- Cyber Kill Chain (Siber Ölüm Zinciri): Bir siber saldırının başlangıcından hedefe ulaşmasına kadar geçen yedi aşamalı (Bilgi toplama, Sömürü vb.) saldırı metodolojisidir.

D

- DoS (Denial of Service): Servis Dışı Bırakma; sunucunun bağlantı havuzunu tüketerek yasal kullanıcıların sisteme erişimini engelleme saldırısıdır.

G

- GET Metodu: HTTP protokolünde kullanıcı verilerinin (kullanıcı adı, şifre vb.) URL adresi üzerinden şifresiz ve açıkça iletildiği yöntemdir.

H

- HSTS: HTTP Strict Transport Security; tarayıcıları web sitesine sadece güvenli HTTPS bağlantısı üzerinden erişmeye zorlayan güvenlik başlığıdır.
- HTTP: Hypertext Transfer Protocol; internette verilerin şifrelenmeden iletildiği temel protokoldür.

I

- Intruder: Burp Suite aracı içerisinde yer alan ve giriş panellerine otomatik saldırılar (kaba kuvvet vb.) düzenlemek için kullanılan modüldür.

M

- MitM (Man-in-the-Middle): Ortadaki Adam Saldırısı; saldırganın kullanıcı ile sunucu arasındaki trafiği gizlice izlemesi veya değiştirmesidir.

O

- OWASP: Open Web Application Security Project; web uygulaması güvenliği konusunda standartlar ve risk listeleri (Top 10) yayınlayan topluluktur.

P

- Plaintext (Açık Metin): Herhangi bir şifreleme işleminden geçmemiş, herkes tarafından okunabilir durumdaki veridir.
- POST Metodu: Verilerin URL yerine HTTP isteğinin gövdesinde (body) gizli olarak gönderildiği daha güvenli bir yöntemdir.

R

- Rate Limiting: Bir sistemin belirli bir sürede kabul edeceği maksimum istek sayısını sınırlayan, kaba kuvvet saldırılarını engelleyen mekanizmadır.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

S

- Slowloris: Web sunucusuna çok yavaş veri göndererek bağlantıları uzun süre açık tutan ve sunucuyu kilitleyen bir DoS saldırı türüdür.
- Sniffing (Koklama): Ağ trafiğinin özel yazılımlar ile izlenerek kullanıcı adı, şifre gibi paketlerin ele geçirilmesi işlemidir.
- SSL/TLS: Verilerin ağ üzerinde şifrelenerek güvenli şekilde iletilmesini sağlayan kriptografik güvenlik katmanlarıdır.

W

- WAF (Web Application Firewall): Web Uygulama Güvenlik Duvarı; web sitelerine gelen zararlı trafiği (SQLi, Brute Force vb.) analiz edip engelleyen sistemdir.

6. Kullanılan Araçlar

6.1. Burp Suite (Intruder)

- Kullanım Amacı: Web uygulamasına yönelik otomatik isteklerin gönderilmesi ve yanıtların analizi.
- İşlevi: Giriş panelinde hız sınırlaması (Rate Limiting) olup olmadığını denetlemek için kısa bir zaman diliminde yüzlerce farklı kullanıcı adı ve parola kombinasyonuyla testler gerçekleştirilmiştir.

6.2. Hydra

- Kullanım Amacı: Hızlı ve ağ tabanlı kaba kuvvet (Brute Force) saldırısı simülasyonu.
- İşlevi: Hedef sistemdeki admin hesabı üzerinde kapsamlı parola listeleri (wordlist) kullanılarak oturum açma denemeleri yapılmış ve zayıf parolanın sömürülmesini sağlamıştır.

6.3. Slowhttptest

- Kullanım Amacı: Uygulama katmanı (Layer 7) Hizmet Dışı Bırakma (DoS) zafiyet testi.
- İşlevi: Sunucuya çok yavaş HTTP başlıkları göndererek bağlantı havuzunun ne kadar sürede tükendiğini ve servisin erişilebilirliğini ölçmek için kullanılmıştır.

6.4. Waterfox / Tarayıcı Geliştirici Araçları

- Kullanım Amacı: İstemci tarafındaki veri iletiminin ve güvenlik sertifikalarının manuel analizi.
- İşlevi: Verilerin URL üzerinden (GET metodu) sızdırıldığının tespiti ve SSL/TLS sertifikasının eksikliğinden kaynaklanan "Güvenli Değil" uyarısının doğrulanması aşamalarında kullanılmıştır.

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.

ÖZDEMİR
SİBER GÜVENLİK

- SON SAYFA -

Bu belge gizli ve özel nitelikli bilgiler içermektedir. Yetkisiz erişim, kopyalama, çoğaltma, dağıtım veya ifşa edilmesi hukuki ve cezai sorumluluk doğurabilir . Doküman hakları saklıdır.